PRÁCTICA CONTRASEÑAS

Práctica Contraseñas

- Enunciado
  - Parte 1: Frases de paso
  - Parte 2: Comparar fortaleza de contraseñas
  - Parte 3: Almacenamiento de contraseñas en Linux y Windows
  - Parte 4: Crackeando contraseñas con John The Ripper
  - Parte 5: Explorando Rainbow Tables
  - Parte 6: Política de contraseñas
- EVALUACIÓN
  - Documento entregado (60%)
  - Defensa oral (40%)

ENUNCIADO

- Crea un documento donde respondas y muestres capturas de pantalla de lo realizado en las diferentes partes:

Parte 1: Frases de paso

- Una frase de paso es una secuencia de palabras, típicamente más larga que una contraseña. Una frase de paso generalmente consiste en una combinación de palabras que son fáciles de recordar, pero difíciles para que otros adivinen o rompan a través de ataques de fuerza bruta. A diferencia de una contraseña tradicional, que suele consistir en una combinación corta de

caracteres (como letras, números y símbolos), una frase de contraseña puede ser más compleja y larga, y puede incluir espacios entre las palabras.

- Uno de los métodos para crear contraseñas seguras es el llamado "Diceware" que se basa en el uso de palabras aleatorias seleccionadas de una lista predefinida. Para crear la contraseña, lanzas un dado 5 veces, y te generará un número de cinco dígitos, que corresponde a una palabra de la lista. Por ejemplo, si tiras y te toca -> 3-2-2-4-1 -> La palabra que corresponde a 32241 es "curro". Repitiendo ese proceso cinco o seis veces se forma una frase de paso, que se puede usar como contraseña. Por ejemplo, `curro-baza-rayo-tarta-mayor-oleaje`. A estas palabras puede añadirle mayúsculas, minúsculas, puntos o símbolos para hacerla más segura: `Curro.baza-rAy0_tArtaA:M@yor!0LEAJE`
- **Accede a lista de diceware en español: DW-Español-1P.doc (si lo prefieres puedes buscar la versión en inglés y usarla, o la versión 2 que hay en español, si es así, indícalo) y genera una frase de paso con 6 palabras usando un dado. Adjunta capturas de todo el proceso.**

Parte 2: Comparar fortaleza de contraseñas

- La web https://www.security.org/how-secure-is-my-password/ permite comprobar la fortaleza de diferentes tipos de contraseña. Ve a la web, y compara cuanto tardaría en crackear diferentes contraseñas.
- Prueba, por ejemplo, `password123`, `P@ssw0rd!`, Tu frase de paso Diceware (sin modificaciones), Tu frase de paso Diceware con las mejoras, o cualquier otra que se te ocurra.
- ¿Cuánto tiempo tardaría un atacante en crackear cada una? ¿Qué diferencia notas entre una contraseña corta y compleja vs. una frase de paso larga? ¿Cuál es más fácil de recordar para ti?

Parte 3: Almacenamiento de contraseñas en Linux y Windows

- En esta parte de la práctica vamos a ver como almacena Kali Linux las contraseñas de los usuarios del sistema. Para ello vamos primero a crear un usuario en nuestra máquina virtual, con el siguiente comando:

```bash
sudo useradd -m nuevousuario #En "nuevousuario" poneis el nombre que querais
```

- Una vez creado, vamos a ver el archivo `/etc/passwd`, el cual contiene información básica de

todos los usuarios del sistema. Para ello usaremos el comando:

```bash
cat /etc/passwd
```

  - ¿Aparece el usuario que acabamos de crear? Investiga que significa cada uno de los campos que aparece por cada usuario. ¿Por qué el segundo campo solo tiene una "x"?

- Por su parte el archivo, `/etc/shadow` contiene las contraseñas hasheadas, y solo puede ser leído por el usuario root, usando el comando:

```bash
sudo cat /etc/shadow
```

  - ¿Aparece el usuario que acabamos de crear? Investiga que significa cada uno de los campos que aparece por cada usuario.
  - Añade una contraseña al usuario que creamos antes con el comando:

```bash
sudo passwd nombredeusuario # En "nuevousuario" poneis el nombre que pusisteis antes
```

  - ¿Se ha actualizado el fichero `/etc/shadow` con la contraseña?

- Localizar en qué fichero(s) y con qué formato se almacenan los resúmenes de las contraseñas en sistemas Windows.

Parte 4: Crackeando contraseñas con John The Ripper

- Ahora vamos a poner en práctica lo aprendido intentando crackear contraseñas débiles.
- Vamos a crearnos en Kali Linux usuarios con contraseñas débiles. Por ejemplo:

```bash
# Crear usuarios de prueba (necesitas ser root)
sudo useradd testuser1
sudo passwd # Cuando pida contraseña: password

sudo useradd testuser2
sudo passwd testuser2 # Cuando pida contraseña: qwerty123

sudo useradd testuser3
```

```
sudo passwd testuser3 # Cuando pida contraseña:P@ssw0rd

sudo useradd testuser4
sudo passwd testuser4 # Cuando pida contraseña: mypassword2025

sudo useradd testuser5
sudo passwd testuser5 # Cuando pida contraseña, pon: tu frase de paso Diceware

sudo useradd testuser6
sudo passwd testuser6 # Pon una contraseña que tu quieras
```

- Desde Kali Linux, copia los archivos de contraseñas:

BASH

```
# Copiar los archivos localmente a una carpeta llamada "practica_passwords"
mkdir practica-passwords #crear carpeta
sudo cp /etc/passwd ~/practica-passwords/passwd-test #copia /etc/passwd a un fichero llamado passwd-test
sudo cp /etc/shadow ~/practica-passwords/shadow-test
```

- Ahora combinamos los archivos para que los pueda usar John The Ripper

BASH

```
cd ~/practica_passwords

# Combinar passwd y shadow
unshadow passwd-test shadow-test > passwords.txt

# Ver el resultado (solo los usuarios de prueba)
grep "testuser" passwords.txt
```

- Ahora usaremos John the Ripper para hacer un ataque con un diccionario de contraseñas comunes:

```bash
# Usar el diccionario básico de John
john --format=crypt --wordlist=/usr/share/john/password.lst passwords.txt

# Ver contraseñas crackeadas
john --show passwords.txt
```

- También podemos usar un diccionario más grande:

```bash
# Verificar si existe rockyou.txt
ls -lh /usr/share/wordlists/rockyou.txt.gz

# Descomprimir si está comprimido
sudo gunzip /usr/share/wordlists/rockyou.txt.gz

# Usar rockyou (tarda muchisimo, DON'T PANIC, si tocas cualquier tecla te sale el % que lleva)
john --format=crypt --wordlist=/usr/share/wordlists/rockyou.txt passwords.txt
```

  - ¿Qué contraseñas logró crackear John?
  - ¿Qué contraseñas NO pudo crackear?
  - Adjunta captura de pantalla con los resultados

- John puede aplicar reglas para crear variaciones de palabras del diccionario:

```bash
# Ver las reglas disponibles
john --list=rules

# Ataque con reglas (convierte palabras: Password, PASSWORD, p4ssword, etc.)
john --wordlist=/usr/share/john/password.lst --rules passwords.txt

# Ver resultados actualizados
john --show passwords.txt
```

  - ¿Logró crackear alguna contraseña adicional con las reglas?

Parte 5: Explorando Rainbow Tables

- Vamos a probar ahora las rainbow tables, las cuales on tablas gigantes precalculadas de hashes. En lugar de calcular el hash de cada contraseña posible en el momento del ataque, estas tablas ya tienen millones de hashes calculados. Es como tener un diccionario gigante de "hash → contraseña". Vamos a probar la rainbow tables con la web: https://crackstation.net/
- Busca estos hashes de MD5 en la rainbow table de la web https://crackstation.net/

```bash
5f4dcc3b5aa765d61d8327deb882cf99
098f6bcd4621d373cade4e832627b4f6
e10adc3949ba59abbe56e057f20f883e
2b249a431be24e6ce35c117d97cd3130
```

  - ¿Qué contraseñas encontró? ¿Fue instantáneo?
- Vamos a crear hashes y ver si podemos crackearlos online.
  - "mipassword" sustitúyelo por `admin`, `123456`, Tu nombre en minúsculas, una contraseña que tú quieras

```bash
# Generar hash MD5 de una contraseña
echo -n "mipassword" | md5sum

# Generar hash SHA-1
echo -n "mipassword" | sha1sum

# Generar hash SHA-256
echo -n "mipassword" | sha256sum
```

  - Busca esos hashes en https://crackstation.net/
  - ¿Pudo CrackStation encontrar tus contraseñas personalizadas? ¿Por qué las contraseñas comunes se encuentran inmediatamente? ¿Qué limitación tienen las rainbow tables?

Parte 6: Política de contraseñas

- Propón una política de contraseñas para una pequeña empresa web (longitud, complejidad, expiración, etc.)

EVALUACIÓN

- Práctica relacionada con RA2 y RA4
- **Faltas de ortografía: -0.25 puntos por falta (máximo -2 puntos, es decir -1.25 de la nota final)**
- La práctica se evaluará, por un lado, el documento entregado, que valdrá un 60%, y, por otro lado, una pequeña defensa oral, que consistirá en mostrar al profesor la práctica realizada, responder alguna pregunta y/o realizar algún cambio o variante en la misma. El peso de la defensa oral será de 40%

Documento entregado (60%)

CRITERIO	EXCELENTE (4)	BIEN (2.5)	SUFICIENTE (1.5)	INSUFICIENTE (0)
1. Parte 1: Creación de frase de paso con Diceware	Genera correctamente frase de paso con Diceware utilizando 6 palabras, documenta todo el proceso con capturas claras (tiradas de dados), muestra la frase original y la versión mejorada con símbolos/mayúsculas	Genera la frase de paso con 6 palabras y documenta el proceso con capturas, aunque falte la frase original o la versión mejorada, o alguna tirada sin capturar	Genera frase de paso con 5-6 palabras con alguna dificultad, documentación básica con capturas incompletas, muestra al menos la frase final	Frase de paso incorrecta o incompleta (menos de 5 palabras), documentación inadecuada o sin capturas, no muestra el proceso
2. Parte 2: Comparación de fortaleza de contraseñas	Prueba todas las contraseñas solicitadas en la web, incluye capturas claras de cada resultado, analiza las diferencias entre tipos de contraseñas, responde todas las preguntas de forma adecuada	Prueba la mayoría de las contraseñas solicitadas, capturas de los resultados principales, analiza brevemente las diferencias, responde la mayoría de las preguntas correctamente	Prueba al menos 3 contraseñas, capturas básicas, análisis superficial de diferencias, respuestas simples, pero correctas	Prueba menos de 3 contraseñas, capturas inadecuadas o ausentes, no analiza diferencias, respuestas incorrectas o ausentes

CRITERIO	EXCELENTE (4)	BIEN (2.5)	SUFICIENTE (1.5)	INSUFICIENTE (0)
3. Parte 3: Almacenamiento en Linux	Crea correctamente el usuario, examina `/etc/passwd` y `/etc/shadow`, explica detalladamente el significado de todos los campos principales, añade contraseña y verifica actualización, responde todas las preguntas de forma adecuada y documenta el almacenamiento en Windows con fuentes	Crea usuario correctamente, examina ambos archivos, explica campos principales correctamente, verifica contraseña, respuestas correctas, investigación básica de Windows	Crea usuario, explicación básica de algunos campos, verifica contraseña, respuestas simples o investigación superficial de Windows	No crea usuario correctamente, no examina archivos, explicación incorrecta o ausente, no verifica contraseña, no investiga Windows
6. Parte 5: Rainbow Tables	Busca correctamente los 4 hashes MD5 proporcionados en CrackStation con capturas, genera hashes MD5/SHA1/SHA256 de al menos 4 contraseñas diferentes (admin, 123456, nombre propio, contraseña inventada), busca todos en CrackStation, responde todas las preguntas de forma adecuada	Busca los 4 hashes proporcionados correctamente, genera hashes de 3-4 contraseñas, busca la mayoría en CrackStation, capturas apropiadas, responde preguntas correctamente con análisis básico	Busca al menos 3 hashes proporcionados, genera hashes de 2-3 contraseñas, busca algunos en CrackStation, capturas básicas, respuestas simples, pero correctas	Busca menos de 3 hashes, genera pocos hashes o con errores, no busca en CrackStation, capturas inadecuadas, respuestas incorrectas o ausentes

CRITERIO	EXCELENTE (4)	BIEN (2.5)	SUFICIENTE (1.5)	INSUFICIENTE (0)
7. Parte 6: Política de contraseñas	Propone política completa y detallada incluyendo: longitud mínima justificada, requisitos de complejidad específicos, período de expiración razonable, gestión de contraseñas anteriores, políticas de bloqueo tras intentos fallidos, considera usabilidad vs. seguridad, justifica cada decisión basándose en lo visto en clase	Propone política adecuada con longitud mínima, complejidad, expiración, considera varios aspectos de seguridad, justificación básica de decisiones basada en la práctica	Propone política básica con longitud y complejidad mínimas, menciona expiración, consideraciones simples de seguridad, justificación limitada	Política incompleta o inadecuada, no especifica requisitos claros, sin justificación, no demuestra comprensión de lo aprendido

CRITERIO	EXCELENTE (2)	BIEN (1.25)	SUFICIENTE (0.75)	INSUFICIENTE (0)
4. Parte 4: John the Ripper - Preparación	Crea correctamente los 6 usuarios de prueba con contraseñas variadas, copia archivos `/etc/passwd` y `/etc/shadow` correctamente, combina con `unshadow` exitosamente, verifica el resultado con grep, documenta todo con capturas claras	Crea 5-6 usuarios correctamente, copia archivos apropiadamente, combina con unshadow, verifica resultado, documentación apropiada con capturas	Crea 4-5 usuarios con alguna dificultad, copia archivos con ayuda, combina correctamente, verificación básica, capturas incompletas	Crea menos de 4 usuarios o con errores, no copia archivos correctamente, falla al combinar, sin verificación, documentación inadecuada
5. Parte 4: John the Ripper - Ataques	Ejecuta correctamente ataque con diccionario básico, rockyou, aplica reglas, documenta resultados de cada ataque con capturas, crea tabla completa identificando qué contraseñas fueron crackeadas y cuáles no, analiza la efectividad de cada método	Ejecuta correctamente el primer ataque, aplica reglas, documenta resultados de cada ataque con capturas, crea tabla completa identificando qué contraseñas fueron crackeadas y cuáles no, analiza la efectividad de cada método	Ejecuta al menos un ataque correctamente, intenta aplicar reglas, documentación básica, identifica algunas contraseñas crackeadas, análisis limitado	Errores en ejecución de ataques, no aplica reglas o falla, documentación inadecuada, no identifica resultados claramente, sin análisis

Defensa oral (40%)

- La rúbrica es general para todas las prácticas. En caso de que uno de los criterios no se

aplique en la defensa, se obtendrá la nota máxima en el mismo para no penalizar.

CRITERIO	EXCELENTE (4)	BIEN (2.5)	SUFICIENTE (1.5)	INSUFICIENTE (0)
Resolución del microcambio / variante planteada	Resuelve correctamente el cambio en el momento, sin pistas	Resuelve correctamente con alguna pista mínima o vacilación	Resuelve de forma parcial o con ayuda notable	No resuelve el cambio o lo hace mal
Comprensión demostrada	Explica con claridad el razonamiento técnico, no solo el resultado	Explica el razonamiento con algún matiz impreciso	Explica de forma superficial, más centrado en describir que en razonar	No sabe explicar el porqué, solo repite lo memorizado.
Autonomía ante lo imprevisto	Se adapta con soltura al cambio pedido	Se adapta con algo de duda inicial, pero llega bien	Necesita bastante guía del profesor	Se bloquea o no sale del guion
Conexión con la teoría	Relaciona explícitamente su respuesta con los conceptos teóricos correspondientes	Relaciona con la teoría de forma correcta, pero menos explícita	Menciona algún concepto de forma vaga	No conecta con ningún concepto teórico